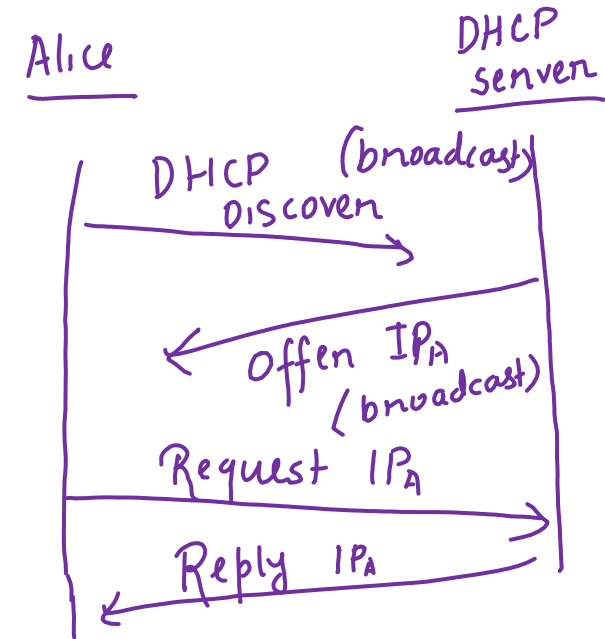
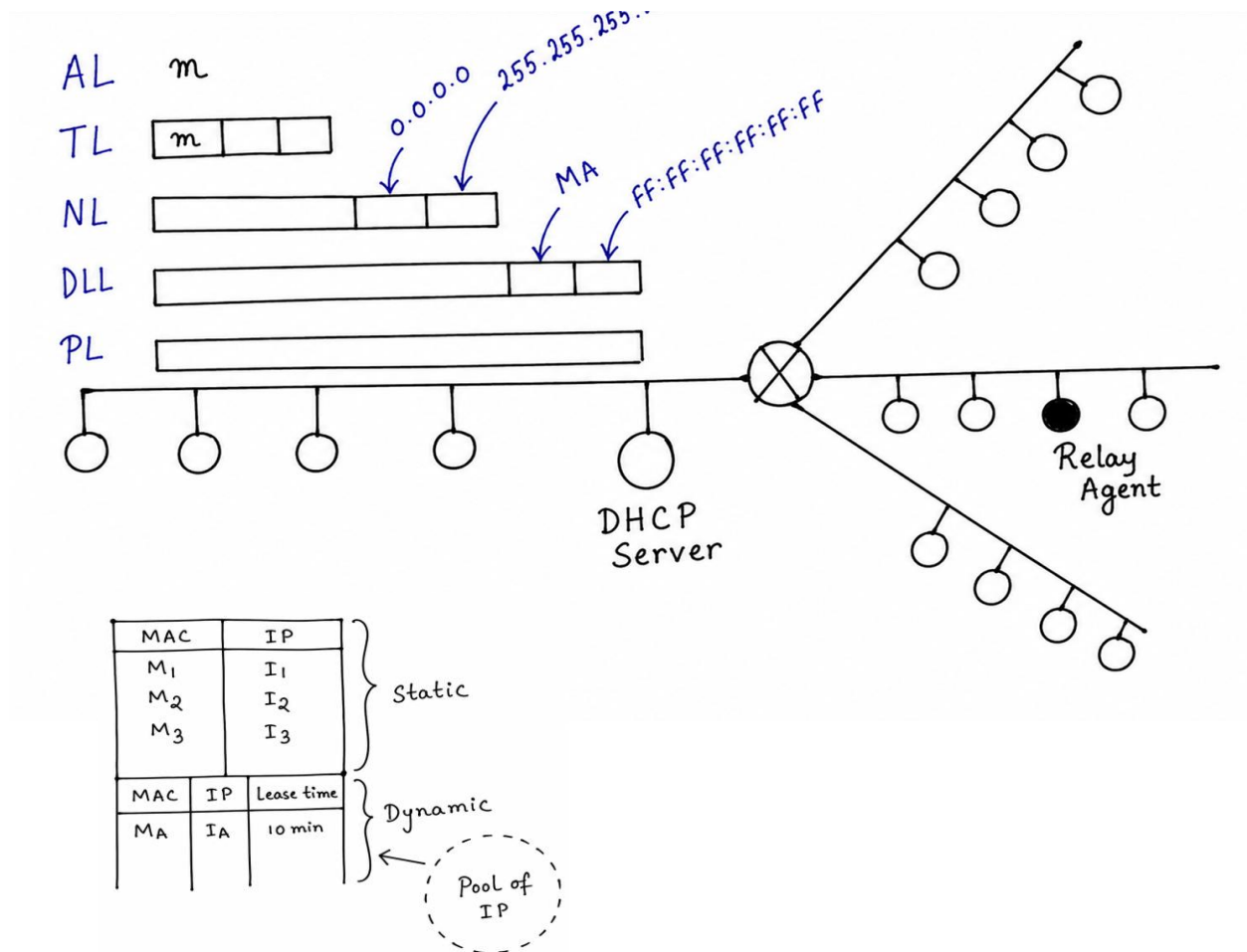


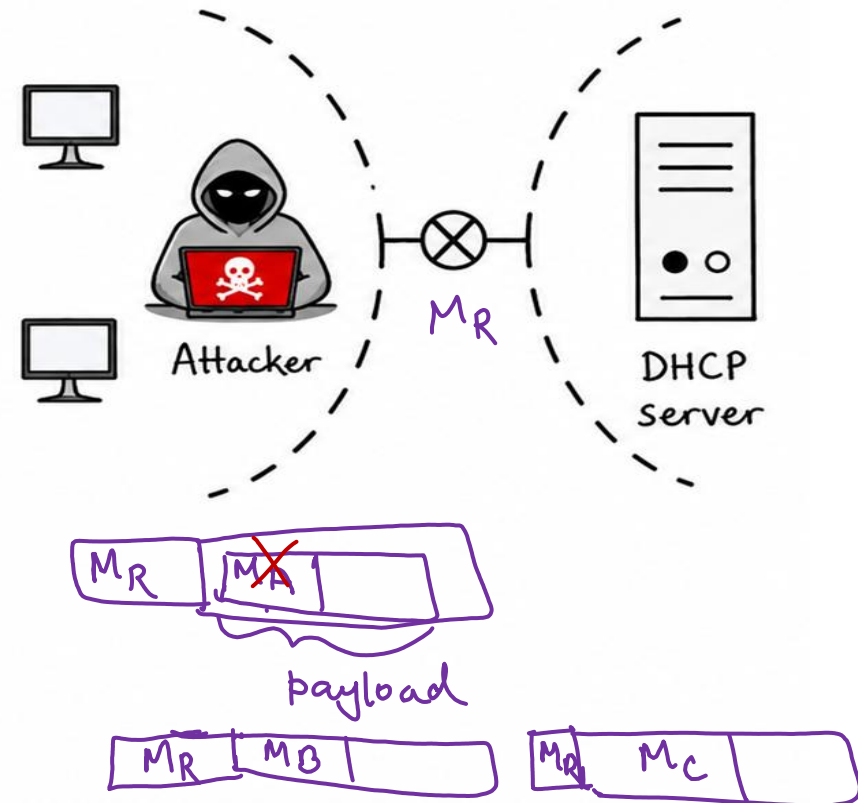
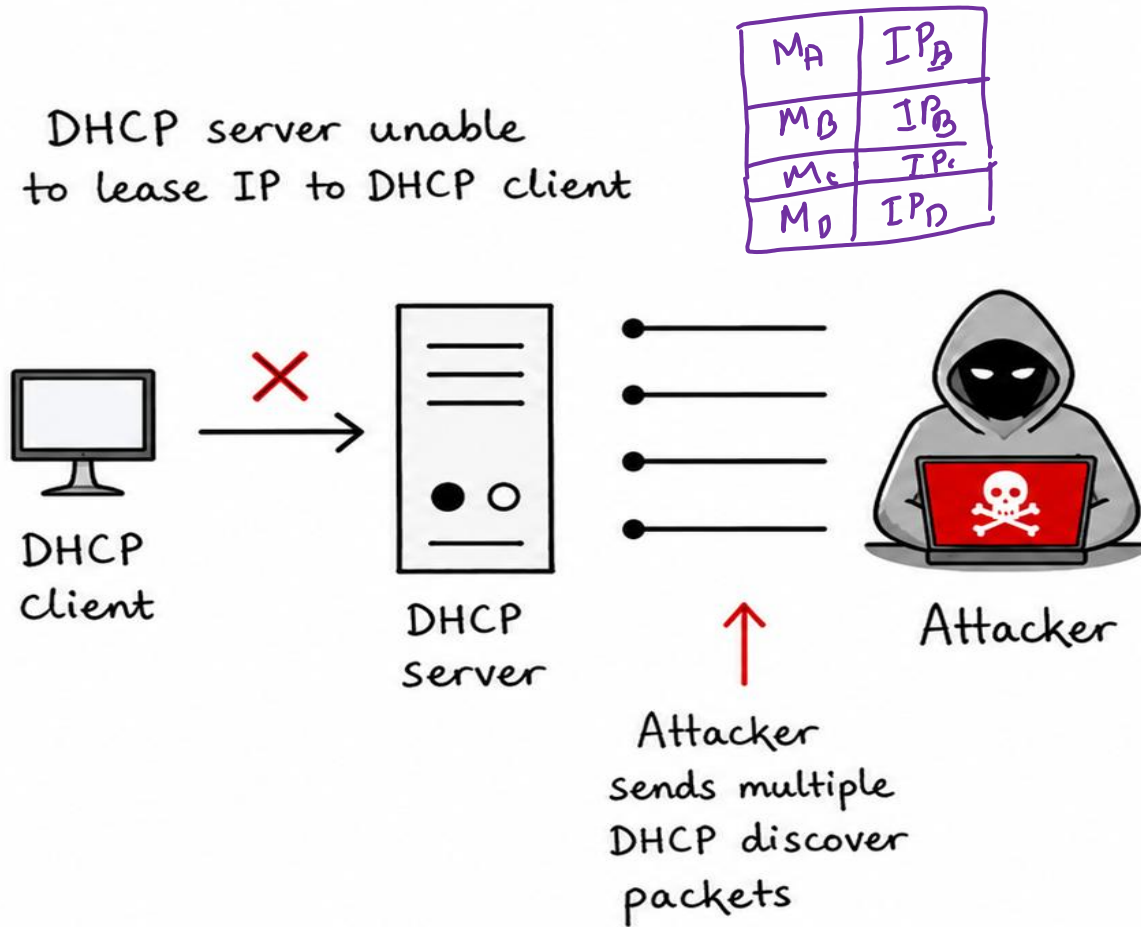
Network Layer and Transport Layer Attacks

-Dr. Sumana Maiti

DHCP Protocol



DHCP Starvation Attack



DHCP Starvation Attack

- Attacker continuously asks for IP address and DHCP server keeps giving IP address.
- Pool of IP is consumed. DHCP Server is unable to give IP to legitimate DHCP Client.
- Can MAC limiting help in this case?
- If DHCP server is present in different network, then source MAC address belongs to router
- Inside the payload specify the MAC address.
- To solve this, relay agent can check whether a same Mac is asking IP for multiple time

Q. Assume a network where:

- The DHCP pool size is 254 addresses
- Average lease time is 24 hours.
- Under normal conditions, about 150 addresses are in use at any time.

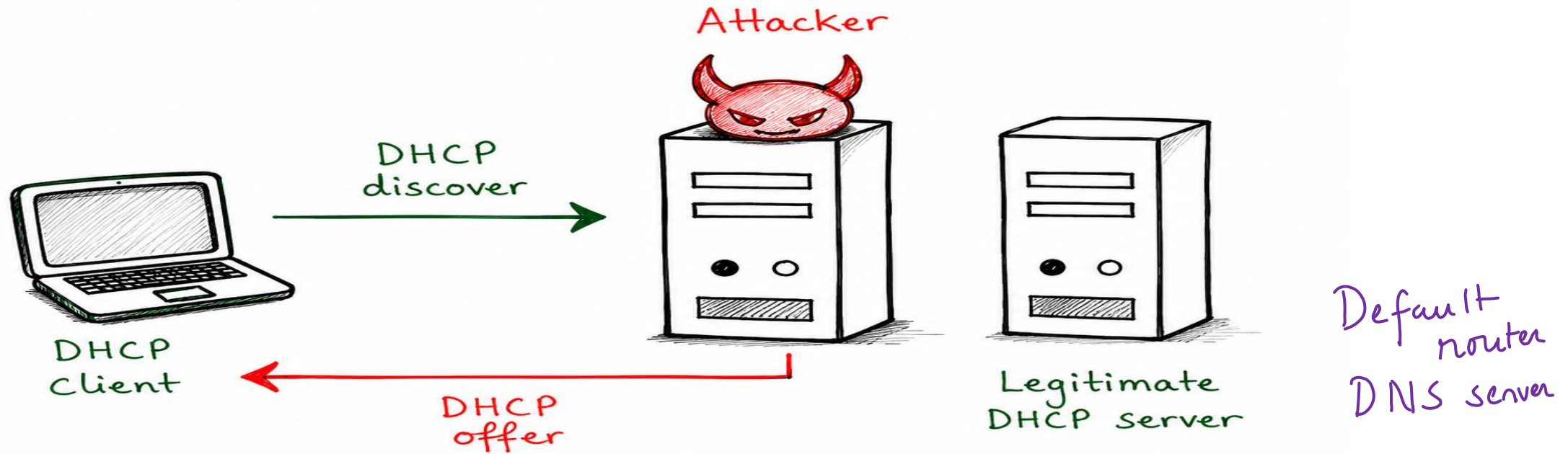
Now suppose an attacker can send 500 DHCPDISCOVER messages per minute with unique MACs.

1. Approximately how long it would take to exhaust the remaining 104 addresses if every request is granted.
2. How the situation would change if the lease time were 1 hour instead of 24 hours.

Answer: $\text{Time} = 104 \text{ requests} / 500 \text{ requests per minute} = 0.208 \text{ minutes}$
 $= 12.5 \text{ minutes.}$

The initial exhaustion time will be unchanged. However, with 1 hour lease time, addresses start expiring and return to pool much faster. Shorter leases reduce the duration of attack time

DHCP Spoofing Attack



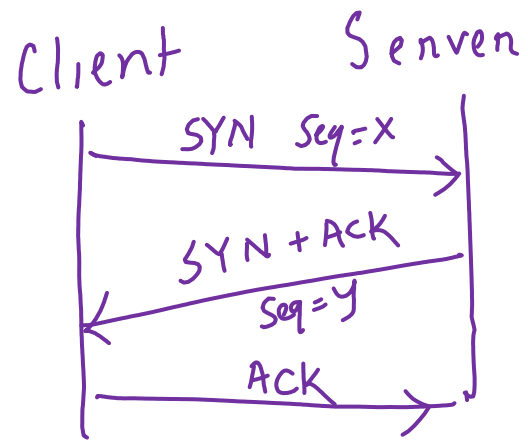
Here, attacker is sending the DHCP offer. It is not mandatory that only one DHCP server runs on one network. Lot of organization runs multiple DHCP server. DHCP client accepts one and reject others

DHCP Spoofing Attack

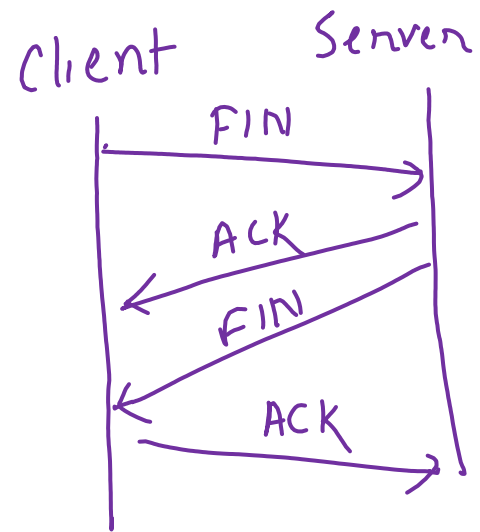
- Here, in place of DHCP server, attacker is sending the offer. It is dangerous as user share lot of information (default router, DNS server)
- If attacker controls DNS server, then it can do phishing attack.
- Attacker is pretending to someone else.
- One solution is “Trusted port”. It will not allow if offer is coming from other ports.

TCP

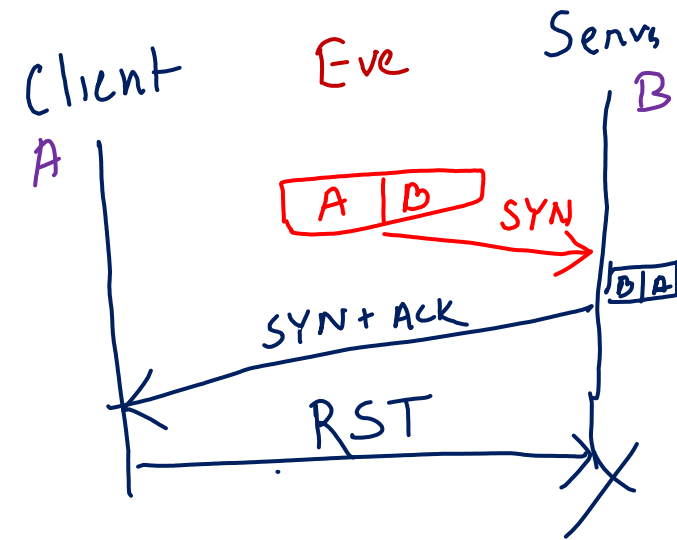
- Before data transmission, client and server need to handshake.
- To close the connection FIN request is sent from client. Server sends ACK. At that time only one side connection is closed. Server can send the data at that time.
- If client sends RST, server immediately closes the connection.
- Seq number is chosen random. Why random?



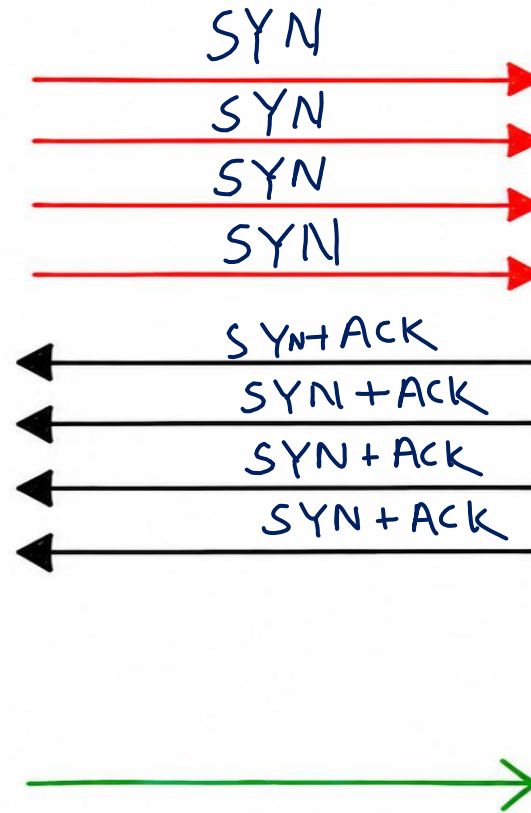
Connection
Establishment



Connection
Termination

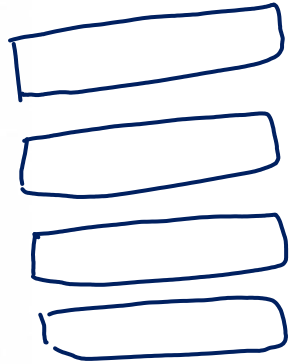


TCP SYN Flood Attack



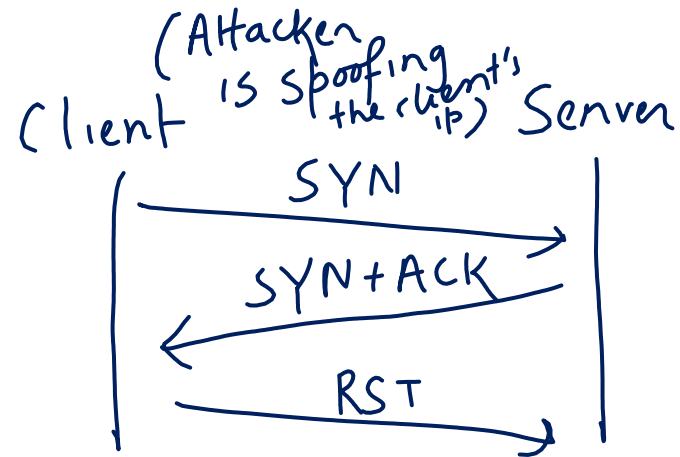
Waiting for Ack
Waiting for Ack
Waiting for Ack
Waiting for Ack

X Connection exhausted



TCP SYN Flood Attack

- This is a type of Denial of Service Attack.
- The idea is to overwhelm the server. The memory is exhausted. If connection is established, then we move to some other memory.



Botnet
(Compromised machine)
under the control of the attacker

TCP SYN Flood Attack(Continue)

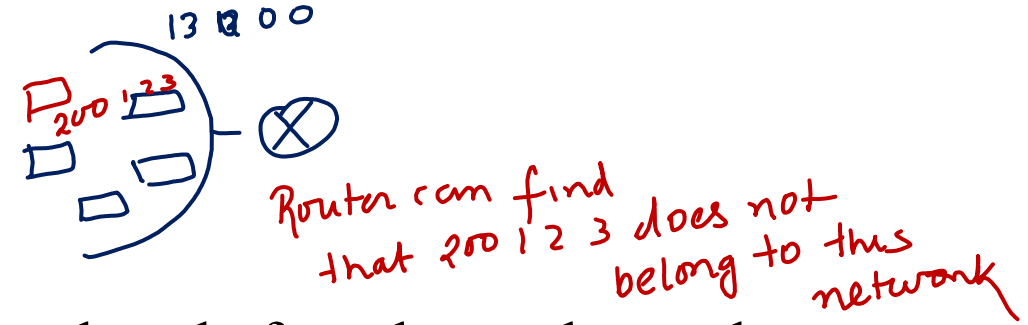
- *When attacker is sending SYN request, can it use same IP address all the time?*
- TCP connection is identified using “source ip, destination ip, source port, destination port”
- Using IP filtering, this attack can be dropped.
- *What will happen, if attacker is spoofing Alice's IP address and send it?*
- In this case the SYN+ACK packet will go to Alice and Alice will reset immediately and memory will be cleared up.
- Hence, if Alice is up, the attack will not

⇒ Server can apply filtering

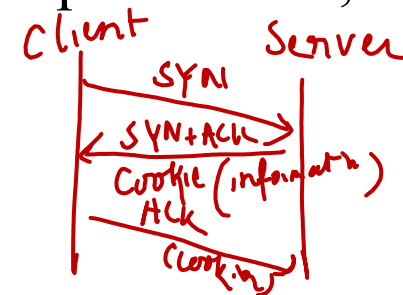
TCP SYN Flood Attack (Continue)

- Another option to launch SYN flood attack is using Botnet.
- Botnet is compromised computer.
- Botnet is under the control of attacker. Attacker is using the IP address of Botnet computer.
- Whenever, the server sends SYN+ACK packet, just ignore (Don't send Ack).

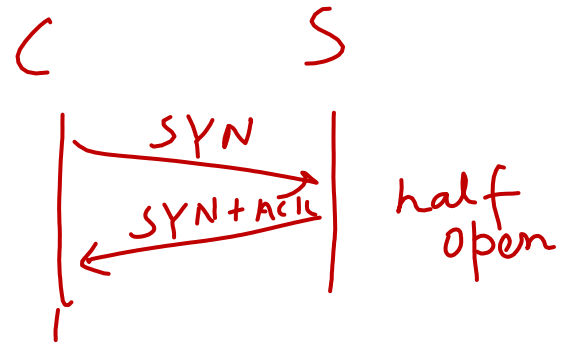
Defense Mechanism?



- **Filtering:** Drop suspicious or spoofed SYN packets before they exhaust the server's half-open connection queue.
- **Ingress Filtering:** Drop incoming packets whose source IP addresses are spoofed or inconsistent with the expected prefixes
- **Cookie (SYN cookie/ TCP Cookie):** Server encodes the connection's essential state (source/destination IP and ports, timestamp, MSS, and a secret) into the initial sequence number of its SYN-ACK. When the client returns the final ACK with the expected sequence number, the server recomputes and verifies the cookie, reconstructs the connection parameters, and only then allocates the full connection state



Q1. Why SYN Flood is called half open attack?



Q2. Why spoofed source IP addresses commonly used in SYN flood?

Q3. Assume a server can hold at most 8192 half-open connections in its SYN backlog. If an attacker sends 50,000 SYNs per second and SYN-received timeout is 30 seconds.

Estimate

- (a) How quickly the backlog will fill?
- (b) Whether reducing the timeout to 5 seconds significantly changes this?

Answer:

Maximum half open connections $B = 8192$,
Attacker SYN rate $R = 50,000$ SYNs/second.

SYN-received timeout $t = 30$ seconds

(a) The number of half-open connections accumulating over time t is $R \cdot t$.

$$t = B/R = 8192/50,000 = 0.164 \text{ seconds.}$$

(a) Effect of reducing timeout from 30s to 5s: Under a continuous flood at 50,000 syns/s, the backlog is dominated by the arrival rate, not the timeout because it fills long before any timeout.

TCP Session Hijacking

- Attacker takes over an already established TCP connection between two hosts by injecting forged packets with correctly predicted sequence number, thereby impersonating one of the endpoints and executing commands or stealing data.



TCP Session Hijacking

- TCP is connection-oriented and relies on sequence (Seq) and acknowledgement (ack) numbers and verify that the packets belong to existing session.
- Once a session is established, the server trusts packets that have the right IP addresses, ports, seq/ack values.
- Attacker will try to (a) see or infer the current seq/ack state, (b) spoof the victim's IP address they can inject packets that the server accepts as legitimate effectively "hijacking" the session.

How TCP session hijacking typically proceeds

- Sniffing: The attacker monitors traffic (eg. compromised router, via ARP spoofing) to learn: (a) source/destination IPs and ports, (b) current sequence and acknowledgement numbers.
- ~~Desynchronization~~: To prevent the legitimate client from interfering, the attacker may (a) flood the client with traffic (b) Send a forged RST/FIN to make the client side connection out of sync, so only the attacker can inject packets and match the server's expected seq/ack.
- Packet injection with correct seq/ack.

TCP Session Spoofing

- The attacker establishes a TCP connection while forging the source IP address to appear as some trusted host.
- How it works:
- Attacker sends a SYN with (i) spoofed source ip = trusted host's ip, (ii) destination ip = victim server.
- To complete the three-way handshake, the attacker must predict or learn the server's initial sequence no to send a valid Ack.